

• Title

- Temporal Memory Safety Bug in `PromptStore` Borrowed Pointer API (Stale Alias / Potential UAF)

• Type / CWE

- CWE-416 (Use After Free, conditional)

ASCAN report

1. Compile with gcc and configure the LLM API.

```
(base) ools@ools: /mnt/c/Users/OoLs/Desktop/trae_projects/work/src$ gcc -fsanitize=address -g -o test *.c
(base) ools@ools: /mnt/c/Users/OoLs/Desktop/trae_projects/work/src$ export PM_API_URL="https://api.deepseek.com"
(base) ools@ools: /mnt/c/Users/OoLs/Desktop/trae_projects/work/src$ export PM_MODEL="deepseek-chat"
(base) ools@ools: /mnt/c/Users/OoLs/Desktop/trae_projects/work/src$ export PM_API_KEY="sk-
(base) ools@ools: /mnt/c/Users/OoLs/Desktop/trae_projects/work/src$ ./test
=====
Prompt Manager (C)
=====
+-----+
| Prompt Operations |
+-----+
1) [P] Save prompt
2) [T] List prompts
3) [S] Search prompts
4) [R] Execute via LLM API
5) [D] Delete prompt
0) Exit
-----
Tip: use comma-separated tags for better filtering.
Select: 1
Prompt name: test
Tags (comma-separated): 11
Prompt content: hello?
Saved.
```

2. Use the prompt saving functionality.

```
Tip: use comma-separated tags for better filtering.
Select: 1
Prompt name: test
Tags (comma-separated): 11
Prompt content: hello?
Saved.
=====
Prompt Manager (C)
=====
+-----+
| Prompt Operations |
+-----+
1) [P] Save prompt
Calling LLM...
AddressSanitizer:DEADLYSIGNAL
=====
==1285==ERROR: AddressSanitizer: SEGV on unknown address 0x000000000000 (pc 0x7cb96979b95c bp 0x7ffe13d13640 sp 0x7ffe13d12dc8 T0)
==1285==The signal is caused by a READ memory access.
==1285==Hint: address points to the zero page.
#0 0x7cb96979b95c (/lib/x86_64-linux-gnu/libc.so.6+0x19b95c) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#1 0x7cb969a7d826 in strlen ../../src/libsanitizer/sanitizer_common/sanitizer_common_interceptors.inc:389
#2 0x6091ab6567c2 in llm_execute_prompt /mnt/c/Users/OoLs/Desktop/trae_projects/work/src/llm_client.c:366
#3 0x6091ab653c97 in execute_prompt /mnt/c/Users/OoLs/Desktop/trae_projects/work/src/cli.c:58
#4 0x6091ab6543ea in run_cli /mnt/c/Users/OoLs/Desktop/trae_projects/work/src/cli.c:124
#5 0x6091ab656b27 in main /mnt/c/Users/OoLs/Desktop/trae_projects/work/src/main.c:26
#6 0x7cb96962a1c9 (/lib/x86_64-linux-gnu/libc.so.6+0x2a1c9) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#7 0x7cb96962a28a in __libc_start_main (/lib/x86_64-linux-gnu/libc.so.6+0x2a28a) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#8 0x6091ab6535e4 in _start (/mnt/c/Users/OoLs/Desktop/trae_projects/work/src/test+0x35e4) (BuildId: e14476c7871249daf918229344df5e5891089ae3)
```

3. Send the prompt to the LLM then trigger a SEGV.

```

1) [P] Save prompt
Calling LLM...
AddressSanitizer:DEADLYSIGNAL
=====
==1285==ERROR: AddressSanitizer: SEGV on unknown address 0x000000000000 (pc 0x7cb96979b95c bp 0x7ffe13d13640 sp 0x7ffe13d12dc8 T0)
==1285==The signal is caused by a READ memory access.
==1285==Hint: address points to the zero page.
#0 0x7cb96979b95c in strlen ../src/..../src/libsanitizer/sanitizer_common/sanitizer_common_interceptors.inc:389
#1 0x7cb96979b95c in llm_execute_prompt /mnt/c/Users/0oLs/Desktop/trae_projects/work/src/llm_client.c:366
#2 0x6091ab653c97 in execute_prompt /mnt/c/Users/0oLs/Desktop/trae_projects/work/src/cli.c:58
#3 0x6091ab653c97 in run_cli /mnt/c/Users/0oLs/Desktop/trae_projects/work/src/cli.c:124
#4 0x6091ab653c97 in main /mnt/c/Users/0oLs/Desktop/trae_projects/work/src/main.c:26
#5 0x7cb96962a1c9 in __libc_start_main (/lib/x86_64-linux-gnu/libc.so.6+0x2a1c9) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#6 0x7cb96962a1c9 in __libc_start_main (/lib/x86_64-linux-gnu/libc.so.6+0x2a1c9) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#7 0x7cb96962a1c9 in __libc_start_main (/lib/x86_64-linux-gnu/libc.so.6+0x2a1c9) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
#8 0x6091ab653c97 in _start (/mnt/c/Users/0oLs/Desktop/trae_projects/work/src/test+0x35e4) (BuildId: e14476c7871249daf918229344df5e5891089ae3)
AddressSanitizer can not provide additional info.
SUMMARY: AddressSanitizer: SEGV (/lib/x86_64-linux-gnu/libc.so.6+0x19b95c) (BuildId: 8e9fd827446c24067541ac5390e6f527fb5947bb)
==1285==ABORTING

```

• Affected Components

- Borrowed pointer source: `prompt_store_get(/src/prompt_store.c#L316-L321)`
- Lifetime invalidators:
 - `prompt_store_delete(/src/prompt_store.c#L304-L313)`,
 - `prompt_store_free(/src/prompt_store.c#L258-L269)`,
 - capacity growth via `realloc` in `ensure_capacity(/src/prompt_store.c#L18-L33)`

• Source

- `Prompt` fields are heap-backed (`dup_str/malloc`) in `prompt_store_add(/src/prompt_store.c#L271-L302)`
- API returns internal element address (`&store->items[index]`) without ownership/lifetime contract in `prompt_store_get(/src/prompt_store.c#L316-L321)`

• Sink

- In `execute_prompt` , alias `p` is acquired, then store entry is deleted, then `p->content` is used:
 - alias acquire: `const Prompt *p = prompt_store_get(store, idx); (/src/cli.c#L49)`
 - invalidation: `prompt_store_delete(store, idx); (/src/cli.c#L54)`
 - post-invalidation dereference: `char *resp = llm_execute_prompt(p->content, user_input); (/src/cli.c#L58)`

• Temporal Gap

- T1: `p = prompt_store_get(store, idx)`
- T2: `prompt_store_delete(store, idx)` triggers `free_prompt` and compaction (`prompt_store.c:L308-L312`)
- T3: dereference stale alias `p->content`

• Alias Lifetime Violation

- Alias type: `const Prompt *` (non-owning, internal borrow)
- Invalidated by:
 - element deletion (`free_prompt`)
 - container destruction (`prompt_store_free`)
 - potential buffer relocation (`realloc`) during `add`
- Root cause: internal pointer exposure without lifetime guarantees or pinning

• Impact

- Immediate path risk: wrong prompt payload used, null/invalid argument propagation, crash depending on callee assumptions
- Extended API risk: if caller caches alias across `delete/free/add(realloc)` and dereferences later, can become true UAF-class behavior

• Exploitability Notes

- This is a logic-driven temporal bug.
- Security relevance rises if downstream callee trusts non-null/valid UTF-8/content invariants

• Evidence Snippets

- Borrow return: `prompt_store.c:L320`
- Free + shift: `prompt_store.c:L308-L312`
- Realloc invalidation potential: `prompt_store.c:L26-L31`
- Same-path stale use in CLI: `cli.c:L49-L58`